

Practical Lab Report

Part 1: Authorized Security Assessment in a Controlled Kali Linux Lab

Field	Details
Student Name	Joseph Osemudiamhen Okoekoh
Student ID	CSC/22/01/0047
Course	COMP404 Computer Security
Lecturer	Dr. George K. Agordzo
Lab Environment	VMware Workstation - Kali Linux (Attacker) and Metasploitable2-Linux (Target)
Date	23 May 2026

1. Introduction

This report documents an authorized security assessment carried out in a controlled lab environment using Kali Linux as the analysis workstation and Metasploitable2 as the target machine. Both virtual machines were configured on the same isolated lab network within VMware Workstation. The objective of this exercise was to practice host discovery, service enumeration, web application review, web server analysis, content discovery, and packet inspection using standard Kali Linux tools (Nmap, Burp Suite, Nikto, Gobuster, and Wireshark), and to document any misconfigurations or weaknesses observed during the assessment.

All activity described in this report was performed strictly within the lab network against the authorized Metasploitable2 target, in line with the rules of engagement defined for this exercise (no scanning of systems outside the lab subnet, no destructive payloads, and no attacks against production systems).

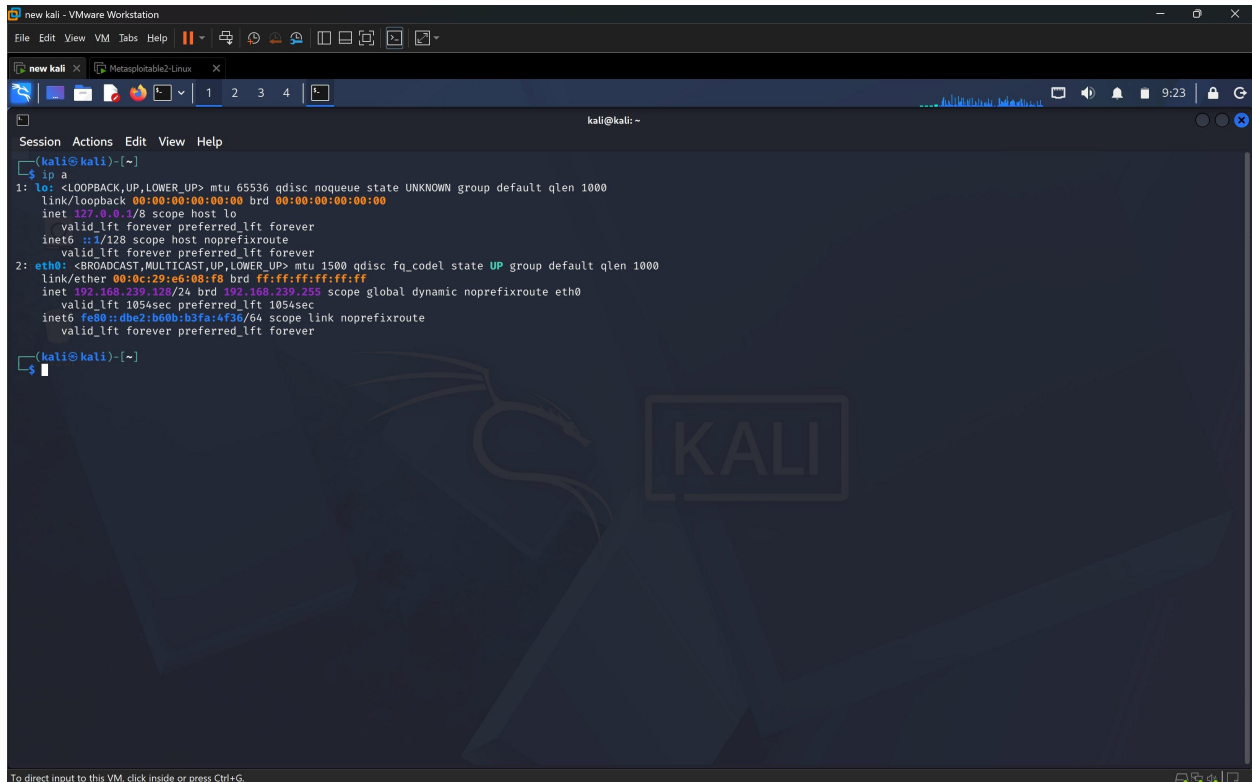
2. Lab Topology and IP Layout

The lab consisted of two virtual machines connected on the same internal/host-only network segment, as summarized below:

Role	Details
Analysis Workstation (Kali Linux)	IP Address: 192.168.239.128/24 MAC Address: 00:0c:29:e6:08:f8 Interface: eth0
Target Machine (Metasploitable2-Linux)	IP Address: 192.168.239.129 MAC Address: 00:0C:29:25:C2:1D
Network Mode	VMware host-only / NAT network (192.168.239.0/24)
Tools Used	Nmap, Burp Suite Community Edition, Nikto, Gobuster,

3. Phase A: Host Discovery and Service Enumeration (Nmap)

The IP address of the Kali Linux workstation was first confirmed using the `ip a` command, which showed the `eth0` interface assigned `192.168.239.128/24`.

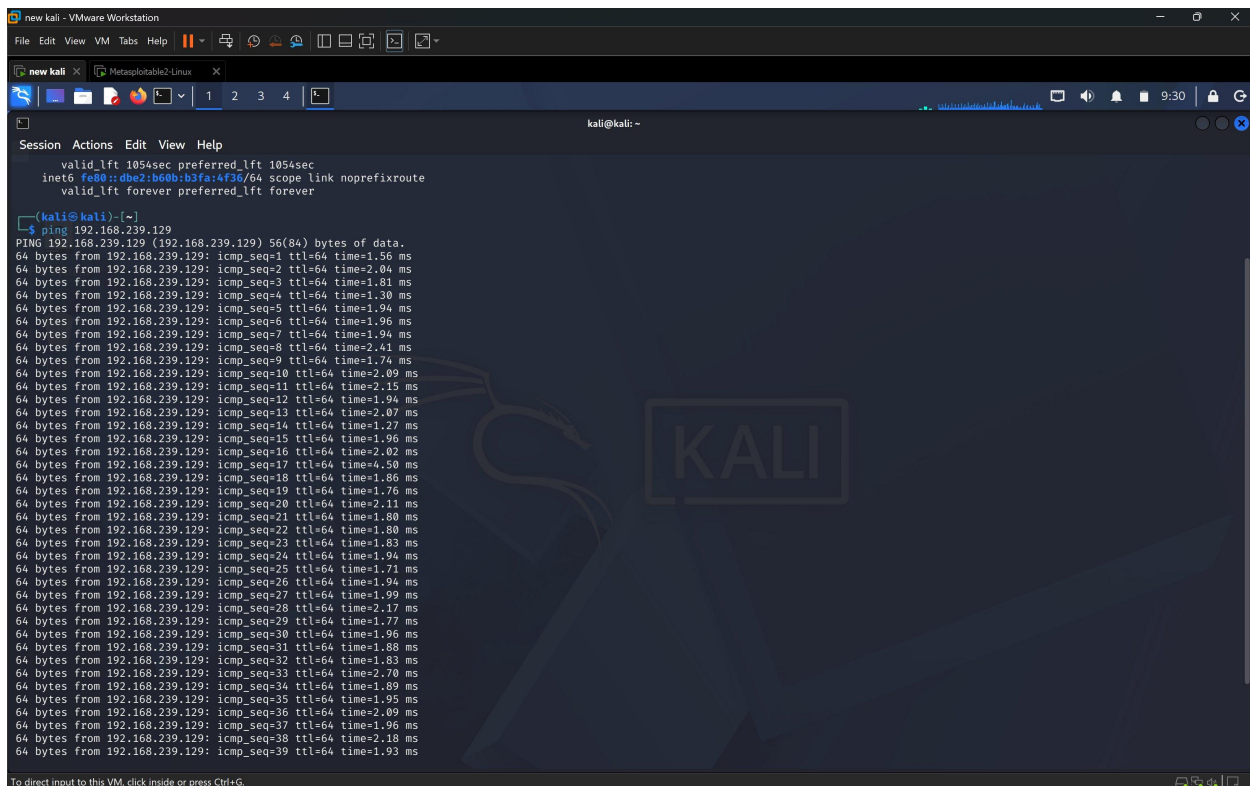


```
(kali@kali)~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:e6:08:f8 brd ff:ff:ff:ff:ff:ff
    inet 192.168.239.128/24 brd 192.168.239.255 scope global dynamic noprefixroute eth0
        valid_lft 1054sec preferred_lft 1054sec
    inet6 fe80::db2:b60b:b3fa:4f36/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@kali)~$
```

Figure 1: 'ip a' output showing the Kali Linux IP address (192.168.239.128).

Connectivity to the target machine (192.168.239.129) was then verified using ping, which returned successful replies with no packet loss, confirming the host was online and reachable.

The image shows a Kali Linux terminal window within a VMware Workstation. The terminal displays the output of a 'ping' command to the IP address 192.168.239.129. The output shows 39 successful ping requests, each receiving 64 bytes of data with varying response times between approximately 1.56 ms and 2.70 ms. The terminal window has a dark background with a 'KALI' logo watermark. The VMware interface at the top shows the 'new kali' VM is running.

```
valid_lft 1054sec preferred_lft 1054sec
inet6 fe80::db2:b60b:b3fa:4f36/64 scope link noprefixroute
valid_lft forever preferred_lft forever

(kali@kali)~$ ping 192.168.239.129
PING 192.168.239.129 (192.168.239.129) 56(84) bytes of data:
64 bytes from 192.168.239.129: icmp_seq=1 ttl=64 time=1.56 ms
64 bytes from 192.168.239.129: icmp_seq=2 ttl=64 time=2.04 ms
64 bytes from 192.168.239.129: icmp_seq=3 ttl=64 time=1.81 ms
64 bytes from 192.168.239.129: icmp_seq=4 ttl=64 time=1.38 ms
64 bytes from 192.168.239.129: icmp_seq=5 ttl=64 time=1.94 ms
64 bytes from 192.168.239.129: icmp_seq=6 ttl=64 time=1.96 ms
64 bytes from 192.168.239.129: icmp_seq=7 ttl=64 time=1.94 ms
64 bytes from 192.168.239.129: icmp_seq=8 ttl=64 time=2.41 ms
64 bytes from 192.168.239.129: icmp_seq=9 ttl=64 time=1.74 ms
64 bytes from 192.168.239.129: icmp_seq=10 ttl=64 time=2.09 ms
64 bytes from 192.168.239.129: icmp_seq=11 ttl=64 time=2.15 ms
64 bytes from 192.168.239.129: icmp_seq=12 ttl=64 time=1.94 ms
64 bytes from 192.168.239.129: icmp_seq=13 ttl=64 time=2.07 ms
64 bytes from 192.168.239.129: icmp_seq=14 ttl=64 time=1.27 ms
64 bytes from 192.168.239.129: icmp_seq=15 ttl=64 time=1.96 ms
64 bytes from 192.168.239.129: icmp_seq=16 ttl=64 time=2.02 ms
64 bytes from 192.168.239.129: icmp_seq=17 ttl=64 time=4.50 ms
64 bytes from 192.168.239.129: icmp_seq=18 ttl=64 time=1.86 ms
64 bytes from 192.168.239.129: icmp_seq=19 ttl=64 time=1.76 ms
64 bytes from 192.168.239.129: icmp_seq=20 ttl=64 time=2.11 ms
64 bytes from 192.168.239.129: icmp_seq=21 ttl=64 time=1.80 ms
64 bytes from 192.168.239.129: icmp_seq=22 ttl=64 time=1.80 ms
64 bytes from 192.168.239.129: icmp_seq=23 ttl=64 time=1.83 ms
64 bytes from 192.168.239.129: icmp_seq=24 ttl=64 time=1.94 ms
64 bytes from 192.168.239.129: icmp_seq=25 ttl=64 time=1.71 ms
64 bytes from 192.168.239.129: icmp_seq=26 ttl=64 time=1.94 ms
64 bytes from 192.168.239.129: icmp_seq=27 ttl=64 time=1.99 ms
64 bytes from 192.168.239.129: icmp_seq=28 ttl=64 time=2.17 ms
64 bytes from 192.168.239.129: icmp_seq=29 ttl=64 time=1.77 ms
64 bytes from 192.168.239.129: icmp_seq=30 ttl=64 time=1.96 ms
64 bytes from 192.168.239.129: icmp_seq=31 ttl=64 time=1.88 ms
64 bytes from 192.168.239.129: icmp_seq=32 ttl=64 time=1.83 ms
64 bytes from 192.168.239.129: icmp_seq=33 ttl=64 time=2.70 ms
64 bytes from 192.168.239.129: icmp_seq=34 ttl=64 time=1.89 ms
64 bytes from 192.168.239.129: icmp_seq=35 ttl=64 time=1.95 ms
64 bytes from 192.168.239.129: icmp_seq=36 ttl=64 time=2.09 ms
64 bytes from 192.168.239.129: icmp_seq=37 ttl=64 time=1.96 ms
64 bytes from 192.168.239.129: icmp_seq=38 ttl=64 time=2.18 ms
64 bytes from 192.168.239.129: icmp_seq=39 ttl=64 time=1.93 ms
```

Figure 2: Successful ping to the target host 192.168.239.129.

A service version scan was then performed using `nmap -sV 192.168.239.129`. The scan completed in 34.26 seconds and reported the target as up, with the following open ports and services identified:

```

kali@kali: ~
Session Actions Edit View Help
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 00:0C:29:25:C2:1D (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.01 seconds

kali@kali:~$ nmap -sV 192.168.239.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-04 09:32 -0400
Nmap scan report for 192.168.239.129
Host is up (0.0026s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet?
25/tcp    open  smtp?
53/tcp    open  domain        ISC BIND 9.4.2
80/tcp    open  http?
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn?
144/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login?
514/tcp   open  shell?
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell     Metasploitable root shell
2049/tcp  open  rpcbind
2121/tcp  open  ccproxy-ftp?
3306/tcp  open  mysql?
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13?
8180/tcp  open  unknown
MAC Address: 00:0C:29:25:C2:1D (VMware)
Service Info: Host: irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 34.26 seconds

kali@kali:~$

```

Figure 3: Nmap service version scan results for 192.168.239.129.

3.1 Open Ports and Services Identified

Port / Protocol	Service / Version
21/tcp	ftp - vsftpd 2.3.4
22/tcp	ssh - OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp	telnet (unidentified version)
25/tcp	smtp
53/tcp	domain - ISC BIND 9.4.2
80/tcp	http (unidentified version)
111/tcp, 2049/tcp	rpcbind
139/tcp, 445/tcp	netbios-ssn - Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/513/514/tcp	exec / login / shell (r-services)
1099/tcp	java-rmi - GNU Classpath grmiregistry
1524/tcp	bindshell - Metasploitable root shell
3306/tcp	mysql

5432/tcp	postgresql - PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp	vnc (protocol 3.3)
6000/tcp	X11 (access denied)
6667/tcp	irc - UnrealIRCd
8009/tcp, 8180/tcp	ajp13 / unknown (Apache Tomcat)

Observation: A very large number of services are exposed on this host, including legacy r-services (exec, login, shell), a deliberately planted root bindshell on port 1524, and an outdated FTP daemon (vsftpd 2.3.4) that is publicly known to contain a backdoor. Telnet (port 23) is also exposed and provides no transport encryption.

4. Phase B: Web Application Review (Burp Suite)

Burp Suite Community Edition was used to intercept traffic between the Kali browser and the target web application. With intercept enabled, a request to the DVWA login page was captured.

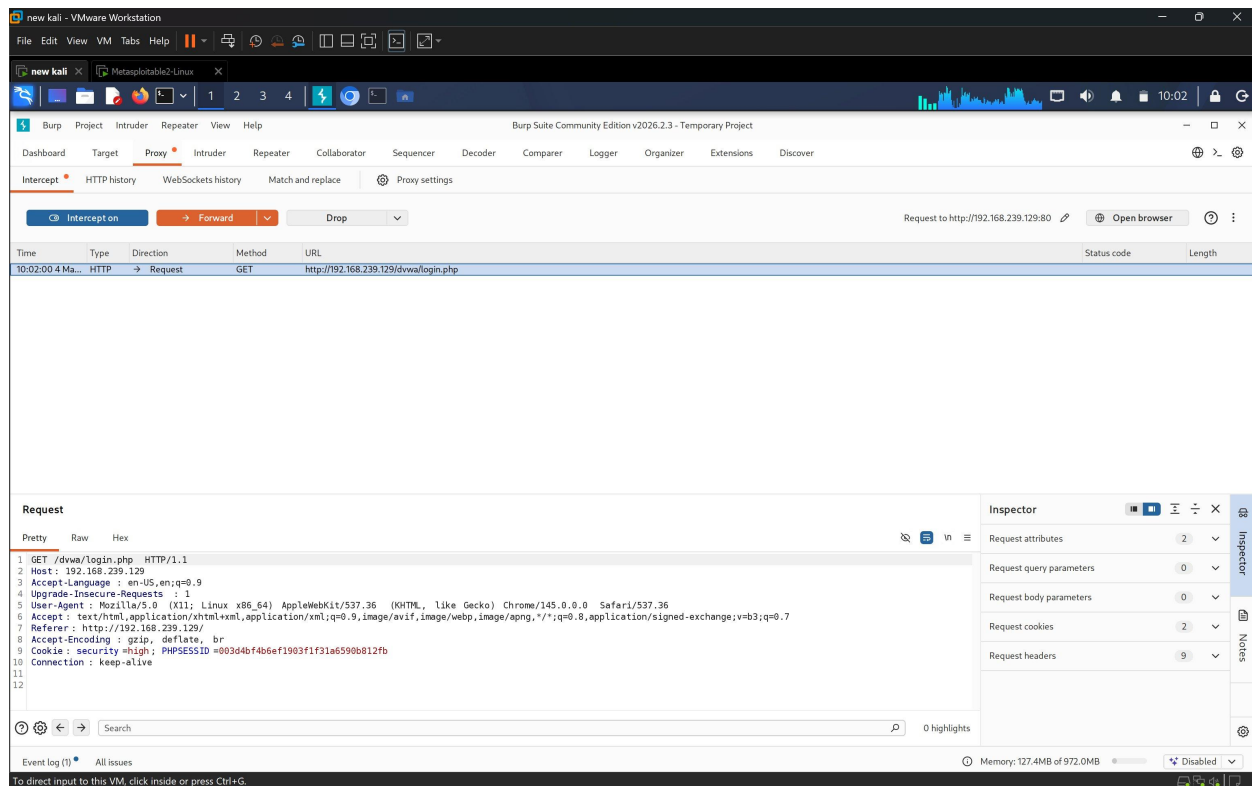


Figure 4: Burp Suite intercepting a GET request to `/dvwa/login.php` on `192.168.239.129`.

The intercepted request shows a GET request to `/dvwa/login.php` over plain HTTP (port 80). The Cookie header includes `security=high` and a `PHPSESSID` session identifier. Because the connection is unencrypted, both the session cookie and the security-level cookie are transmitted in clear text and could be intercepted by anyone on the same network segment.

5. Phase C: Safe Web Server Review (Nikto)

Nikto was run against the target web server using `nikto -h http://192.168.239.129 -o nikto_report.txt`. The scan identified a substantial number of configuration weaknesses and outdated software components, summarized below:

- The server discloses an outdated technology stack: PHP/5.2.4-2ubuntu5.10 and Apache/2.2.8, both several major versions behind current supported releases.
- Directory indexing (browsable file listings) is enabled on `/icons/`, `/doc/`, and `/test/`.
- `phpinfo.php` is present and accessible, revealing detailed PHP configuration and environment information.
- A `phpMyAdmin` installation is present and reachable, including its changelog and README files, which can reveal version information useful to an attacker.
- The HTTP TRACE method is enabled, which can be leveraged for Cross-Site Tracing (XST) attacks.
- Several recommended security headers are missing, including Content-Security-Policy, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy, and Permissions-Policy.
- The server responds to known PHP 'Easter egg' query strings, which can leak version and build information.
- Apache `mod_negotiation` with MultiViews is enabled, which can make it easier for an attacker to enumerate file names on the server.

As noted in the lab guidance, these Nikto results were treated as potential findings rather than confirmed issues; several were cross-checked against the Gobuster results and manual browsing in Phase D and Phase B.

6. Phase D: Content Discovery (Gobuster)

Gobuster was used to discover unlinked directories and files on the target web server using the `common.txt` wordlist from `dirb`:

```
new kali - VMware Workstation
File Edit View VM Tabs Help
new kali x Metasploitable2-Linux x
kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ gobuster dir -u http://192.168.239.129 -w /usr/share/wordlists/dirb/common.txt
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
[+] Url: http://192.168.239.129
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
Starting gobuster in directory enumeration mode
.hta (Status: 403) [Size: 292]
.htaccess (Status: 403) [Size: 297]
.htpasswd (Status: 403) [Size: 297]
cgi-bin/ (Status: 403) [Size: 296]
dav (Status: 301) [Size: 321] [→ http://192.168.239.129/dav/]
index.php (Status: 200) [Size: 891]
index (Status: 200) [Size: 891]
phpMyAdmin (Status: 301) [Size: 328] [→ http://192.168.239.129/phpMyAdmin/]
phpinfo (Status: 200) [Size: 48029]
phpinfo.php (Status: 200) [Size: 48041]
test (Status: 301) [Size: 322] [→ http://192.168.239.129/test/]
twiki (Status: 301) [Size: 323] [→ http://192.168.239.129/twiki/]
server-status (Status: 403) [Size: 301]
Progress: 4613 / 4613 (100.00%)
Finished
(kali@kali)-[~]
$
```

Figure 5: Gobuster directory discovery results for `http://192.168.239.129`.

6.1 Notable Results

Path	Status / Notes
/phpMyAdmin	301 redirect - database management interface exposed
/phpinfo, /phpinfo.php	200 OK - exposes full PHP configuration (CWE-552)
/test/	301 redirect - leftover test directory, browsable
/twiki/	301 redirect - additional application exposed
/dav/	301 redirect - WebDAV directory
/cgi-bin/, .htaccess, .htpasswd, .hta	403 Forbidden - present but access denied
server-status	403 Forbidden - Apache status module present but restricted

Discussion: An exposed phpMyAdmin path is risky because, if default or weak credentials are in use, it gives an attacker direct access to the application's databases. Similarly, leftover directories such as /test/ and /twiki/ increase the attack surface and may contain outdated or vulnerable code that was never intended to be reachable from the web.

7. Phase E: Packet Inspection (Wireshark)

Wireshark was used to capture traffic on the eth0 interface while browsing the target normally from Firefox.

Applying the http filter showed a series of plaintext HTTP requests and responses between the Kali host (192.168.239.128) and the target (192.168.239.129), including requests to /phpMyAdmin/, /dvwa/, /dvwa/login.php, and /twiki/, all returned over unencrypted HTTP on port 80.

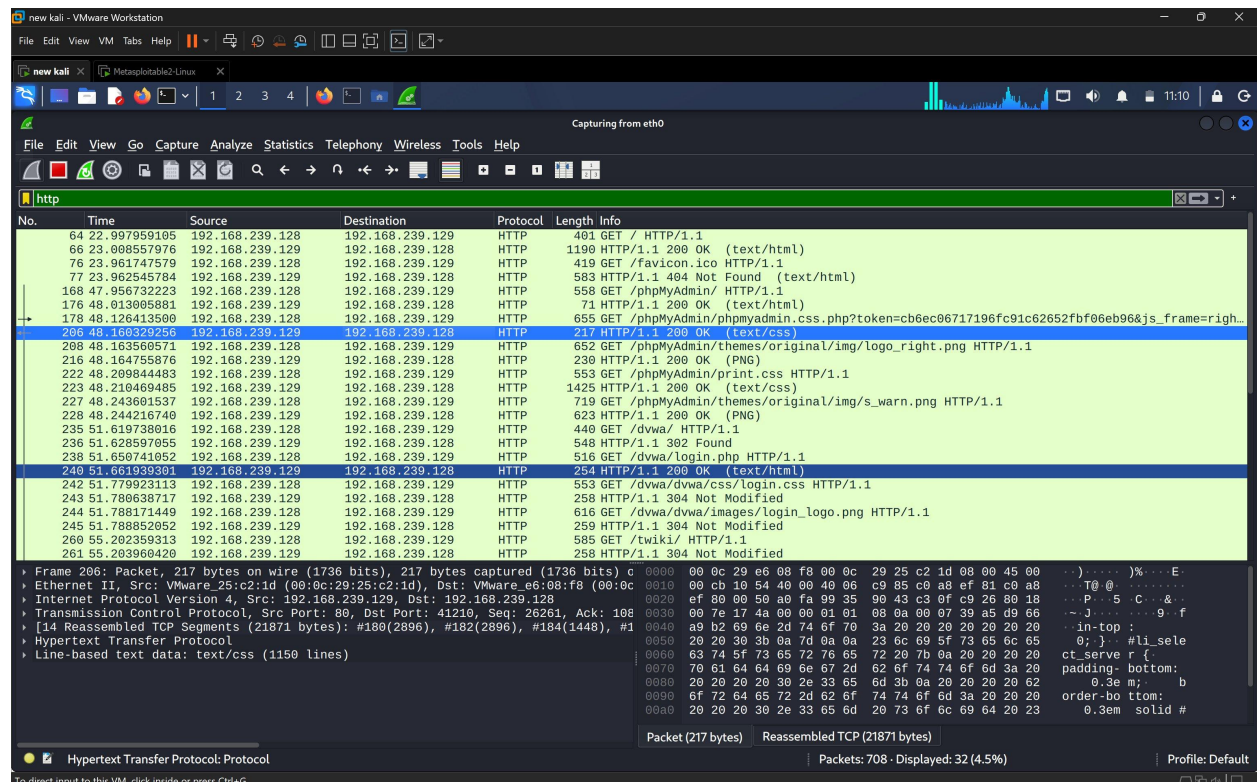


Figure 6: Wireshark capture filtered on 'http', showing plaintext HTTP requests to /phpMyAdmin/ and /dvwa/.

Applying the dns filter showed multiple DNS queries generated by the Kali host while browsing, mostly background lookups from Firefox (e.g. detectportal.firefox.com, location.services.mozilla.com) and NTP time synchronization queries (1.debian.pool.ntp.org).

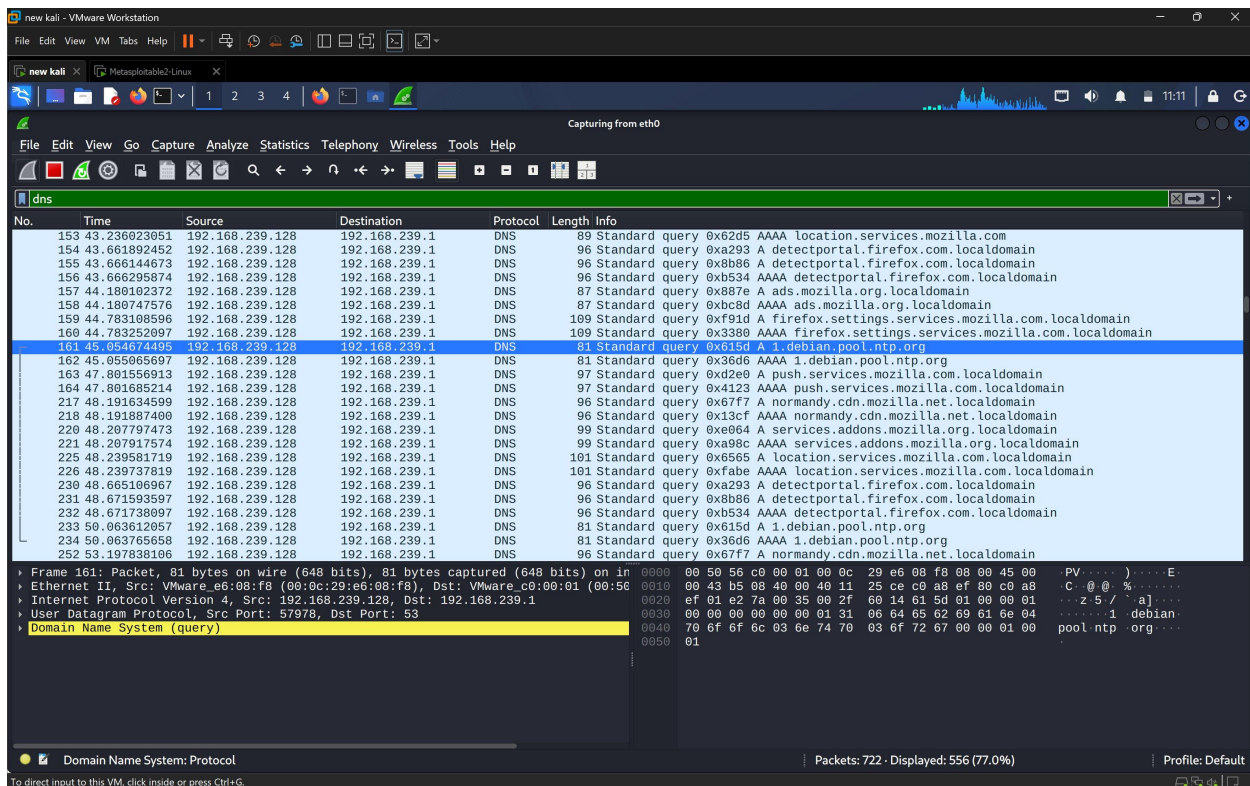


Figure 7: Wireshark capture filtered on 'dns', showing background DNS queries from the Kali workstation.

Observation: Because the web application is served over plain HTTP, all requests, responses, and cookies (including the PHPSESSID and security level cookies observed in Burp Suite) are visible in clear text to anyone capturing traffic on this network segment. No HTTPS traffic was observed during this capture.

8. Findings Table

The table below summarizes the key findings from this assessment, the tool/evidence source, an assessed risk level, and a recommended remediation for each.

#	Finding / Vulnerability	Evidence Source	Risk Level	Recommendation
1	vsftpd 2.3.4 running on port 21 (FTP) — this version contains a known backdoor vulnerability (CVE-2011-2523) allowing remote root access.	Nmap (-sV)	Critical	Upgrade vsftpd to a patched version; disable FTP entirely if not required; restrict access by firewall/IP allow-list.
2	Telnet service exposed on port 23. Telnet transmits credentials and data in plain text and has no encryption.	Nmap (-sV)	High	Disable Telnet and replace with SSH for all remote administration.
3	Large number of unnecessary services exposed (rpcbind, NFS, X11, IRC/UnrealIRCd, Java RMI, VNC, bindshell on 1524), increasing the attack surface.	Nmap (-sV)	High	Disable or remove all services that are not required for the system's function; apply the principle of least functionality.
4	Web server running outdated Apache 2.2.8 and PHP 5.2.4-2ubuntu5.10, both well past end-of-life and missing years of security patches.	Nikto	High	Upgrade Apache and PHP to currently supported versions and apply vendor security patches.
5	phpinfo.php and a phpMyAdmin installation are publicly accessible, exposing detailed configuration and database management interfaces.	Nikto / Gobuster	High	Remove phpinfo.php from production; restrict phpMyAdmin to localhost or an authenticated VPN, and enforce strong credentials.
6	Directory indexing is enabled on /icons/, /doc/, and /test/, exposing file and folder listings to any visitor.	Nikto / Gobuster	Medium	Disable directory indexing (Options -Indexes in Apache configuration) and remove unused sample directories such as /test/.
7	HTTP TRACE method is enabled, which can facilitate Cross-Site Tracing (XST) attacks used to steal cookies and session tokens.	Nikto	Medium	Disable the TRACE/TRACK HTTP methods in the web server configuration.
8	Web application served entirely over unencrypted HTTP, with session cookies (e.g. PHPSESSID,	Wireshark / Burp Suite	High	Implement HTTPS/TLS site-wide, redirect all HTTP traffic to HTTPS, and set the Secure and HttpOnly flags on session cookies.

	security=high) transmitted in clear text.			
9	Missing recommended security headers (Content-Security-Policy, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy, Permissions-Policy).	Nikto	Medium	Configure the web server to send modern security headers to reduce the risk of clickjacking, MIME-sniffing, and related attacks.

9. Conclusion and Recommendations

This assessment of the Metasploitable2 target machine identified a large number of misconfigurations and outdated, vulnerable services. The most severe issues were the presence of a known-vulnerable FTP daemon (vsftpd 2.3.4) and an unauthenticated root bindshell on port 1524, both of which would allow an attacker to gain full control of the system with minimal effort. The web application layer added further risk, with an outdated Apache/PHP stack, an exposed phpMyAdmin interface, directory indexing, and a complete lack of transport encryption that exposes session cookies and credentials to anyone monitoring the network.

Overall recommendations:

- Patch and update all exposed services (FTP, SSH, Samba, BIND, Apache, PHP, PostgreSQL) to currently supported versions.
- Remove or disable unnecessary services such as r-services (exec/login/shell), the root bindshell on port 1524, X11, and IRC.
- Disable Telnet and enforce SSH for all remote administration.
- Implement HTTPS/TLS across the web application, redirect all HTTP traffic to HTTPS, and apply Secure and HttpOnly flags to session cookies.
- Restrict or remove administrative interfaces such as phpMyAdmin, and remove leftover/test directories (e.g. /test/, phpinfo.php).
- Disable directory indexing and the HTTP TRACE method, and configure recommended security headers (CSP, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy, Permissions-Policy).

Taken together, these changes would significantly reduce the attack surface of the target system and bring it closer to a secure baseline configuration.